

```

import { getDatabase } from "@netlify/database";

const db = getDatabase();

export default async (req) => {
  const url = new URL(req.url);
  const code = url.searchParams.get("code");

  if (!code) {
    return new Response(JSON.stringify({ error: "Access code required" })), { status: 401 }
  }

  try {
    const [client] = await db.sql`SELECT * FROM clients WHERE access_code = ${code}`;
    if (!client) {
      return new Response(JSON.stringify({ error: "Invalid access code" })), { status: 401 }
    }

    if (req.method === "GET") {
      // Scoped strictly to this client's own id - this is the actual privacy boundary
      const [jobs, invoices] = await Promise.all([
        db.sql`SELECT * FROM jobs WHERE client_id = ${client.id}::uuid ORDER BY date`,
        db.sql`SELECT * FROM invoices WHERE client_id = ${client.id}::uuid ORDER BY date`
      ]);
      return Response.json({ client, jobs, invoices });
    }

    if (req.method === "POST") {
      // Client requesting a new job - always created as "requested", always tied to client
      const body = await req.json();
      const [job] = await db.sql`
        INSERT INTO jobs (client_id, date, time, type, price, status, notes)
        VALUES (${client.id}::uuid, ${body.date}, ${body.time}, ${body.type}, 0, 'requested', ${body.notes})
        RETURNING *
      `;
      return Response.json(job);
    }

    return new Response("Method not allowed", { status: 405 });
  } catch (err) {
    console.error(err);
    return new Response(JSON.stringify({ error: String(err) })), { status: 500 };
  }
};

```

```
export const config = { path: "/api/client" };
```